IdentityGuard: Session Risk & ATO Detection

System Architecture, Specification Compliance (R1–R11) & Master Execution Blueprint

Domain: Domain 2 — AI Systems & Infrastructure	**Target Event Schema:** Strict 5-Field Ingress (R1)
Problem Statement Code: A-03 (Official Booklet)	**AI Governance Rule:** AI Strictly Advisory (R9 Invariant)
Session Gate Enforcement: Hard Lockout & Refusal (R11)	**Audit Integrity:** Cryptographic SHA-256 Hash Chained (R8)
Replay Determinism: Bit-Exact Decision Stream Hash (R10)	**Current Verification:** 53/53 Automated Tests Passing (100%)

1. Executive Overview & Problem Statement Context

Traditional perimeter authentication verifies credentials only once at login. Attackers effortlessly bypass this gate via session hijacking, infostealer malware cookies, credential stuffing, and reverse-proxy phishing. **IdentityGuard** is an enterprise-grade continuous session risk evaluation engine built specifically to solve Challenge **A-03** in Domain 2 (AI Systems & Infrastructure). It evaluates every action in an active session, computes deterministic mathematical signals, applies evidence-aware behavioral profiling, leverages Markov sequence pattern recognition under compile-time and runtime circuit breakers, and enforces immutable session revocations.

2. Unified Dual-Layer Architecture

The architecture unifies the core deterministic pipeline with the merged DY Patil CounterStrike components into an end-to-end zero-trust security infrastructure:

Layer	Core Responsibility	Technology & Guarantee
Ingress Layer	Accepts strict 5-field events: timestamp, user, device_id, location_label, action. No IP or network fingerprint required.	FastAPI, Pydantic V2. Validates UTC offset, checks clock skew, normalizes location aliases via geodesic DB.
Session Gate (R11)	Pre-check verification. If session is terminally revoked, hard-refuse action with HTTP 403 SESSION_REVOKED.	SQLite transactional store. Ensures ZERO profile learning from events submitted on dead sessions.
Signal Engine (S1–S6)	Computes reproducible risk signals: S1 unfamiliar device, S2 geodesic travel velocity (>900 km/h), S3 unusual hour (<2%), S4 sensitive action post-login (<30m).	Haversine Great Circle geodesic calculation; circular smoothed 24-hr histogram P(h); device progression state machine.
AI Sequence Advisory	Evaluates action sequences for takeover signatures (e.g., login $\to$ view_settings $\to$ change_email $\to$ transfer_funds).	Markov transition matrix + Gemini heuristic fallback. Strictly guarded: cannot trigger automated response alone (R9).
Rule Engine & Resolver	Declarative YAML DSL (config/rules.yaml) with evidence-aware resolution and strict precedence hierarchy.	Precedence: REVOKE > STEP_UP > ANALYST_REVIEW > NO_ACTION. Fallback to analyst review on limited data.

Audit & Replay Ledger	Immutable audit trail chained by SHA-256 row hashes (R8); Sandboxed Replay Engine producing deterministic stream hashes (R10).	SHA-256 cryptographic chaining; isolated in-memory replay sandbox with candidate policy delta comparator.
Unified Presentation	1. Analyst SOC Studio (diurnal chart, audit table, signals) 2. React 18 World Threat Map (interactive attack vectors) 3. Apex Global Bank Target App (live 403 enforcement).	Tailwind CSS, React 18, Vite 5, Chart.js, Lucide Icons, FastAPI static serving on Port 8000.

3. Specification Compliance Matrix (R1 through R11)

IdentityGuard strictly implements all 11 core requirements specified in the official booklet and guidelines. Every requirement is codified in automated test suites and verified 100% passing:

Req ID	Specification Requirement	Implementation Mechanism in IdentityGuard	Status
R1	Strict 5-Field Ingress	Engine accepts only [ts, user, device, loc, action]. No IP or network ASN required.	**PASSED**
R2	Deterministic Signals	Reproducible signals S1–S4 computed mathematically via Haversine and smoothed diurnal bins.	**PASSED**
R3	Evidence-Aware Profiling	Graduated data sufficiency: NONE (<5), LIMITED (5–19), SUFFICIENT (≥20). Zero false guesses.	**PASSED**
R4	Declarative YAML Rules	Rules codified in human-readable YAML (config/rules.yaml) with compile-time AST validation.	**PASSED**
R5	Strict Precedence Order	Precedence resolution: REVOKE > STEP_UP > ANALYST_REVIEW > NO_ACTION.	**PASSED**
R6	Out-of-Order Telemetry	Ordering handler detects timestamp skews, tags late_event warnings, and prevents profile poisoning.	**PASSED**
R7	Plain-English Explanations	Multi-tier plain-English narrative for SOC analysts and end users without technical jargon.	**PASSED**
R8	Immutable Audit Ledger	Cryptographically hash-chained audit log (SHA-256) with automated tamper-break verification.	**PASSED**
R9	AI Strictly Advisory	AST compiler check and runtime circuit breaker prevent AI from triggering automated responses alone.	**PASSED**
R10	Deterministic Replay	Sandboxed in-memory replay engine computing identical SHA-256 decision stream hash and delta diffs.	**PASSED**
R11	Terminal Revocation Gate	Once revoked, subsequent actions are hard-refused with HTTP 403 and blocked from profile learning.	**PASSED**

4. Pre-Packaged Demo Scenarios for Hackathon Jury

IdentityGuard pre-seeds realistic personas and attack vectors demonstrating the exact sequence of detection and enforcement:

Scenario 1: Full Account Takeover (ATO) Chain (Asha / Alice)

- **Baseline:** Established 6-day profile (30 events) operating 09:00–18:00 IST from Pune via laptop.
- **Attack Login:** Attacker logs in at 03:15 AM IST from an unfamiliar device (triggers S1 + S3 $\to$ **R-04 STEP_UP**).
- **Credential Tampering:** Attacker requests change_email 4 minutes later (triggers S4 $\to$ **R-06 REVOKE**).
- **Enforcement (R11):** Attacker attempts request_transfer $\to$ **Hard Refused with HTTP 403 SESSION_REVOKED**.

Scenario 2: Impossible Geodesic Travel Velocity (David)

- Active legitimate session in Pune, IN.
- 15 minutes later, an event is submitted from London, UK (>7,300 km away $\to$ computed velocity ~29,200 km/h).
- Triggers S2 Implausible Travel Velocity (>900 km/h limit) $\to$ **R-07 Immediate Session Revocation**.

Scenario 3: Sparse Baseline & Cold-Start Evidence Handling (Elena)

- New user with fewer than 15 historical events (<5 active days).
- Sensitive password change on an unfamiliar device triggers **R-05 STEP_UP** with explicit LIMITED evidence statement, preventing false-positive confidence.

5. Master Execution Roadmap: Remaining Hackathon Stages

The following sequential stages finalize the system into an enterprise-ready hackathon winner:

Stage	Objective & Key Deliverables	Verification Metric
Stage A Unified Bridge	Bridge React UI telemetry directly into the primary SecurityPipeline and SHA-256 audit ledger. Synchronize dynamic policy sliders with YAML thresholds.	Events from Threat Map reflect in primary DB & audit log.
Stage B Real-Time Stream	Implement Server-Sent Events (SSE) / WebSockets feed (/api/stream/events) broadcasting live decisions to SOC Studio and Threat Map.	Flashing visual radar updates in real-time without page refresh.
Stage C Gemini AI Forensics	Integrate Google Gemini 2.5 Flash to generate executive SOC threat forensics and MITRE ATT&CK; mappings (T1078, T1539) with offline venue fallback.	Deep threat hypothesis modal generated on-demand.
Stage D 2FA Challenge	Implement complete interactive step-up lifecycle: step_up trigger $\to$ OTP challenge $\to$ validation $\to$ session state transition to active.	End-to-end 2FA recovery in target banking app.
Stage E Jury Pitch Package	Deliver 120-second judge demonstration script (JUDGE_DEMO_WALKTHROUGH.md), updated master guide, and offline 1-click boot bundle.	Flawless 2-minute live jury demonstration.

6. System Verification & Live Deployment

All 53 unit and integration tests are verified passing via pytest. The entire multi-interface suite runs with a single command:

```
python run.py
```

Live Interface Endpoints:

- **Analyst SOC Command Center:** http://127.0.0.1:8000/
- **React 18 World Threat Map:** http://127.0.0.1:8000/react_app.html
- **Protected Apex Global Bank App:** http://127.0.0.1:8000/bank_app.html
- **Interactive Swagger Documentation:** http://127.0.0.1:8000/docs